Threat Model

For threat modelling, I'm considering a few threat actors and then trying to build layered controls around them.

Threat actors:

- Bot/crawlers/scanners: Use public endpoint to start
- Compromised tenant: has code execution in its own pods and then can exec code in other tenant pod (lateral movement)
- Malicious deployment: can create pod with privileged or untrusted image
- Supply chain: pulling malicious image (their code in our cluster)

Control by layers:

Layer	Threat	Control	Gap
Node	Ssh brute force, exposed ports exploitation	Ufw with default deny, allowing only 22 on cp-1 with root off	22 is still open, vpn can be a option
Node	Workload on control plane	Tainted cp	Single control plane, so if down whole cluster is gone, basically no availability
Control plane	Api server publicly reachable	6443 not public, kubectl only via ssh tunnel	
Control plane	Api abuse getting undetected	Rke2 CIS default profile	Custom audit policy and logs not on cp
Etcd	Plaintext content	Encrypted seret in etcd by default using rke2	
secrets	Plaintext secret read	Sealed secrets, git only has ciphertext	ESO is better
Network	Lateral movement and exfiltration	Cilium default deny in non platform namespace, fqdn allowlist	
Network	Metadata or kubelet	Cluster wide deny to	

	cred theft	169.254.169.254 and port 10250 (for kubelet)	
Network	Node to node traffic on internet	Wireguard for pod traffic and tls for cp traffic	
Pod	Privileged, host mount, root, sa token theft	Kyverno PSS restricted, read only root filesystem, sa mounting false	Platform namespace need rbac review since they have exception for now
Supply chain	Mutable tags, tampered or untrusted images	Image pinned by digest, cosign keyless signing and verification using kyverno, also ci workflow with trivy scan	
Tenancy/sandboxing	runc/Kernel escape	Untrusted code in gvisor runtime class enforced by kyverno policy	Other tenant still shares host kernal, host falco can not see calls inside gvisor
Gitops	Tenant can change their own boindaries	AppProject per tenant, and edit allowed only for their own namespace	
Detection	Shell in running container	Falco	Can only be done for tenant not in gvisor
Detection	Policy changes, cves, scanning	Alerts on admission denials, network policy drops, critical CVEs	